

From Pain Points to Automation: Support for Privacy Assessments

[Mugdha Khedkar](#)

Heinz Nixdorf Institute,
Paderborn University (Germany)



Our Group

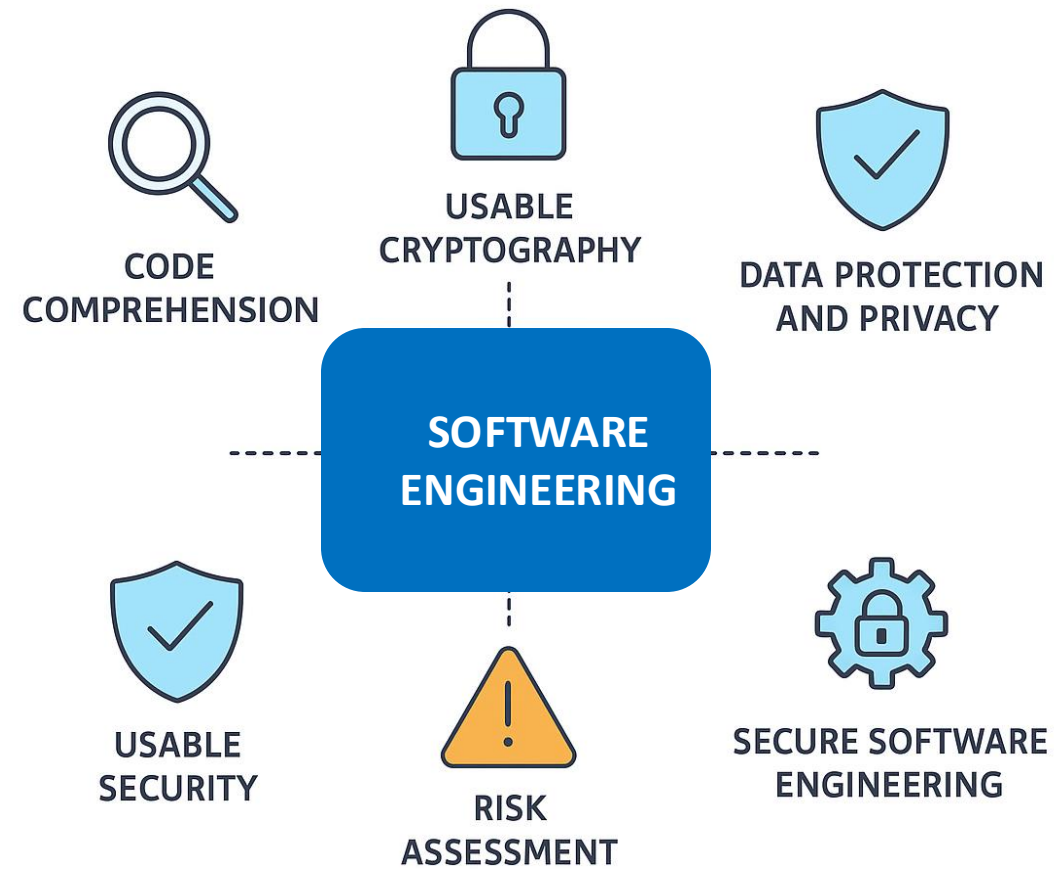
Secure Software Engineering, Paderborn University (Germany)



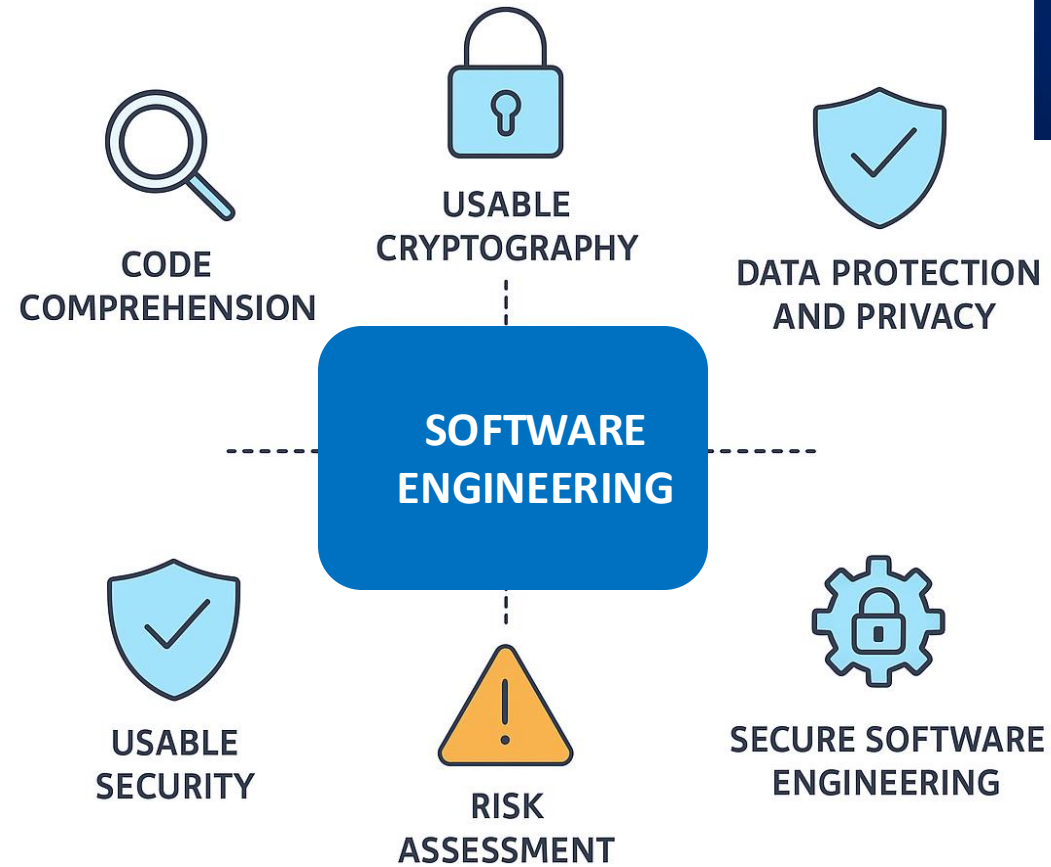
What we do

**SOFTWARE
ENGINEERING**

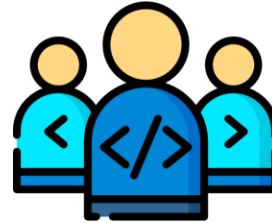
What we do



What we do



- Most of our tools are built for developers.



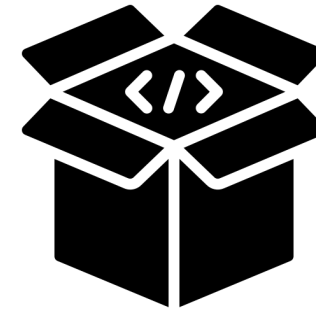
- But software impacts many stakeholders, including DPOs.



The Challenge

Software as a Black Box

- DPOs often rely on developer reports to understand systems.
- Actual data flows can be hidden or undocumented.
- This creates uncertainty and risk.

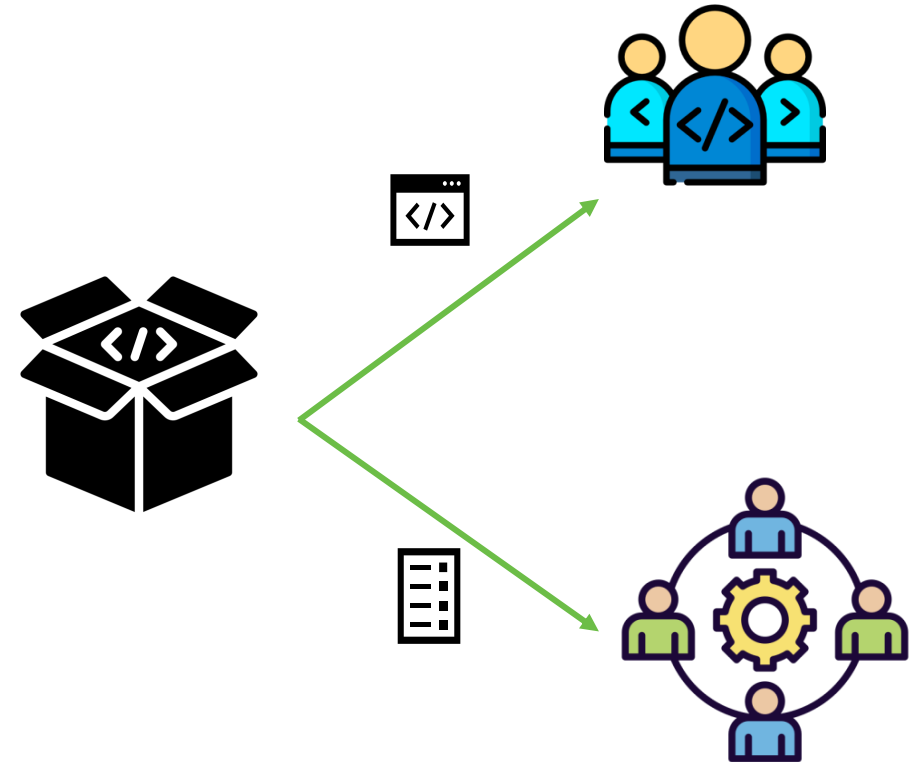


Our Goal

Transparency and Proof

We aim to make software behavior:

- **Transparent**: understandable to non-developers.
- **Traceable**: linked to source evidence.
- **Provable**: reproducible and verifiable.



From Code to Compliance

Static analysis enables us to:

- Observe code without executing it.
- Identify data processing operations.
- Map them to privacy documentation (e.g., RoPA, DPIA).

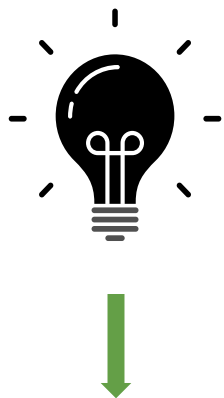


From Code to Compliance

Static analysis enables us to:

- Observe code without executing it.
- Identify data processing operations.
- Map them to privacy documentation (e.g., RoPA, DPIA).

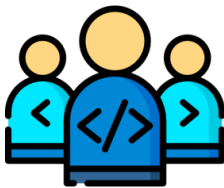
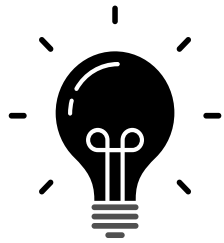




Toward an Android Static Analysis Approach for Data Protection

Mugdha Khedkar
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
mugdha.khedkar@upb.de

Eric Bodden
Heinz Nixdorf Institute
Paderborn University and Fraunhofer IEM
Paderborn, Germany
eric.bodden@upb.de



Toward an Android Static Analysis Approach for Data Protection

Mugdha Khedkar
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
mugdha.khedkar@upb.de

Eric Bodden
Heinz Nixdorf Institute
Paderborn University and Fraunhofer IEM
Paderborn, Germany
eric.bodden@upb.de

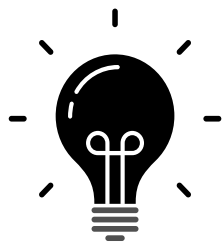
[2]

Do Android App Developers Accurately Report Collection of Privacy-Related Data?

Mugdha Khedkar
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
mugdha.khedkar@uni-paderborn.de

Ambuj Kumar Mondal
Paderborn University
Paderborn, Germany
ambuj.mondal@gmail.com

Eric Bodden
Heinz Nixdorf Institute
Paderborn University and Fraunhofer IEM
Paderborn, Germany
eric.bodden@uni-paderborn.de



Toward an Android Static Analysis Approach for Data Protection

Mugdha Khedkar
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
mugdha.khedkar@upb.de

Eric Bodden
Heinz Nixdorf Institute
Paderborn University and Fraunhofer IEM
Paderborn, Germany
eric.bodden@upb.de

Do Android App Developers Accurately Report Collection of Privacy-Related Data?

Mugdha Khedkar
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
mugdha.khedkar@uni-paderborn.de

Ambuj Kumar Mondal
Paderborn University
Paderborn, Germany
ambuj.mondal@gmail.com

Eric Bodden
Heinz Nixdorf Institute
Paderborn University and Fraunhofer IEM
Paderborn, Germany
eric.bodden@uni-paderborn.de

Advancing Android Privacy Assessments with Automation

Mugdha Khedkar
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
mugdha.khedkar@uni-paderborn.de

Michael Schlichtig
Heinz Nixdorf Institute
Paderborn University
Paderborn, Germany
michael.schlichtig@uni-paderborn.de

Eric Bodden
Heinz Nixdorf Institute
Paderborn University and Fraunhofer IEM
Paderborn, Germany
eric.bodden@uni-paderborn.de

Introduction to the Session

PURPOSE

- Understand the **practical challenges** DPOs & privacy experts face during privacy assessments.
- Explore where **automation or tool support** could make their work more efficient, reliable, and scalable.

Introduction to the Session

PURPOSE

- Understand the **practical challenges** DPOs & privacy experts face during privacy assessments.
- Explore where **automation or tool support** could make their work more efficient, reliable, and scalable.

REMINDER

This is a brainstorming session, not a finalized solution demo.

Session Agenda

1. Discussion on pain points (10 min)
2. Research insights & interview highlights (10 min)
3. Assessor View prototype demo (10 min)
4. Group hands-on activity (40 min)
5. Reflection & synthesis (20 min)

Discussion on Pain Points

Discussion

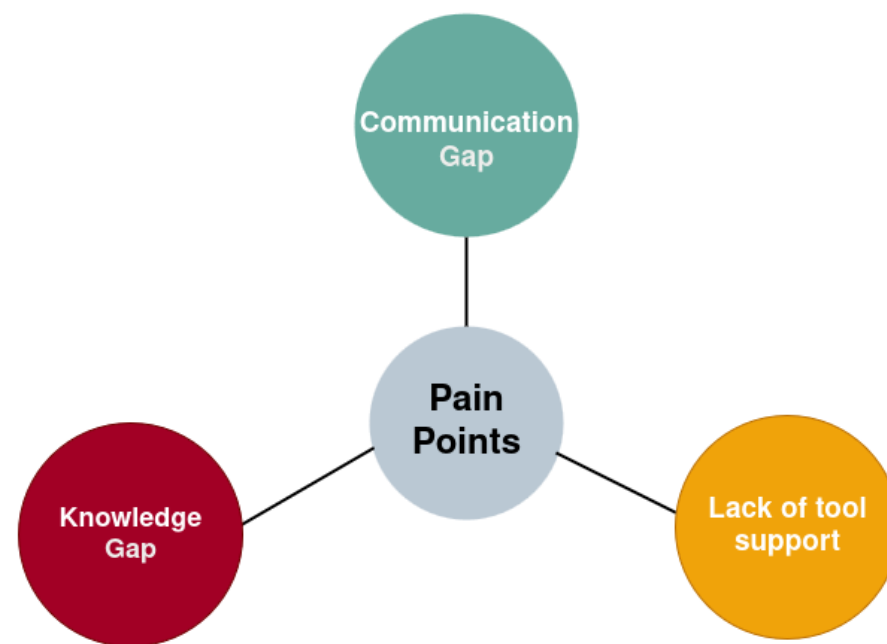
What is the hardest part of conducting a privacy assessment?



Research Insights and Interview Highlights

Common Pain Points

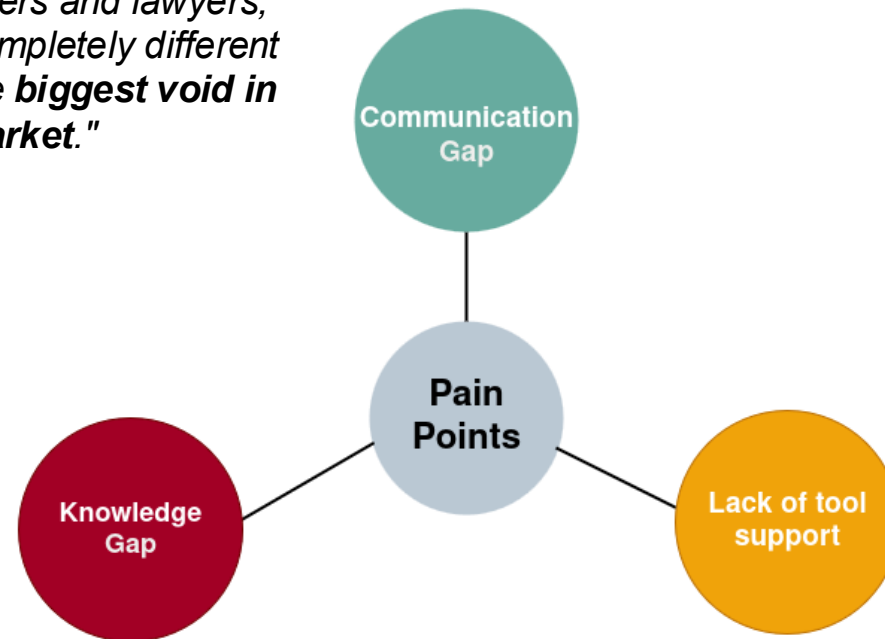
From Interview Studies with DPOs



Common Pain Points

From Interview Studies with DPOs

*"There is **no communication** between developers and lawyers, they are in two completely different worlds. This is the **biggest void in the market.**"*



*"Legal team drafting DPIA would have to discuss stuff with a developer. A developer is not going to give them legal answers. There has to be some **common ground**, which doesn't exist."*

*"I have never seen **automated code scanning** from privacy point of view (so far). Most tools are more focused on **security**, not on GDPR compliance part apart from Article 32 (security of processing)."*

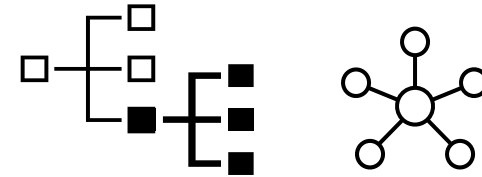
Key Takeaways from Interviews

- Privacy assessments for GDPR compliance (DPIAs) are conducted **manually**.
- **Record of Processing Activities (RoPA)** is the most important document for GDPR compliance, often used as starting point for DPIAs.
- Only **partial** automation of documentation is possible, since experts prefer to manually complete part of documentation (eg., purpose of processing).

Introducing Assessor View

An academic prototype [4] using static analysis to

- Visualize source code for non-technical stakeholders.



- Automatically generate partial RoPA.



Assessor View Prototype Demo

Demo: Assessor View in Action

Step 1: Analyze Android App

Analyze Your Android Application

Upload an Android App (.apk) to Analyze

Browse...

No file selected.

Select Risks: 0

All Risks

☐ Developer Options

Analyze

Try Demo App

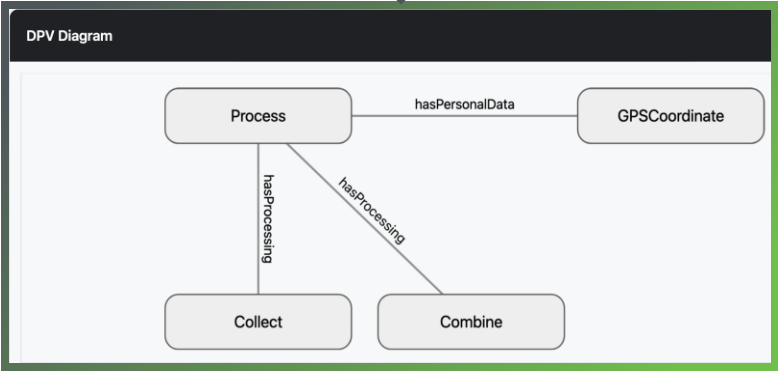
Try our demo app to see how the analysis works



Step 2: View the Dashboard



Step 3: Visualize source code



Step 4: Generate RoPA

Personal Data	Process Activity	Description of Processing Activity	Third Party Libraries	Purpose	GDPR Articles	Special Categories of Data?	DPO Remarks
Approximate location	Collect	To gather data from someone.	Not Found	Enter purpose for the processing activity here	§ 13 § 25	Is this a special category of Data?	Enter DPO remarks
	Combine	To join or merge data.	Not Found	Enter purpose for the processing activity here			
Phone number	Collect	To gather data from someone.	Not Found	Enter purpose for the processing activity here	§ 13 § 25	Is this a special category of Data?	Enter DPO remarks
	Combine	To join or merge data.	Not Found	Enter purpose for the processing activity here			

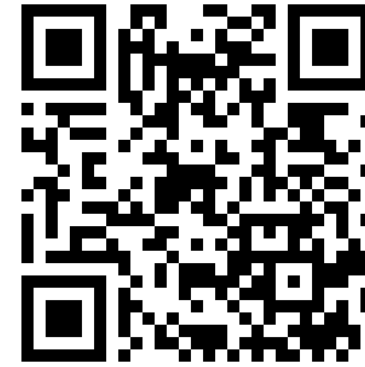
Group Hands-On Activity

Group Activity Instructions



Hands-On Exercise:

- Form small groups (3–5 participants)
- Access the tool link: <https://assessorview.cs.upb.de/> OR Scan:
- Tasks:
 - Analyze any demo Android application.
 - Explore the tool interface.
 - Identify gaps or challenges.
 - Note potential improvements.



Group Work Prompts

Focus Questions:

1. How easy is it to interpret the output?
2. What more information would you need in a DPIA or a pre-DPIA screening process?
3. Where could a tool like this fit in your workflow?
4. What gaps would need to be addressed before you could integrate a tool like this into your workflow?



Reflection and Synthesis

Revisiting Pain Points



Initial Pain Points	Tool Response

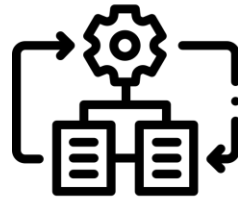
- ✓ Addressed by automation
- ⚙ Partially addressed
- ✗ Still open

Looking Ahead

- Scaling automation responsibly.



- Integrating with compliance systems.



On the job market
for 2026.

Contact



Mrs. Mugdha Khedkar

Heinz Nixdorf Institute
Paderborn University
Fürstenallee 11
33102 Paderborn
Germany

Tel +49 5251 60-6584
Webpage <https://mugdhak30.github.io/>
Email mugdha.khedkar@upb.de



[@KhedkarMugdha](#)



[Mugdha Khedkar](#)



[Mugdha Khedkar](#)

References

- [1] Mugdha Khedkar and Eric Bodden. 2024. Toward an Android Static Analysis Approach for Data Protection. In Proceedings of the IEEE/ACM 11th International Conference on Mobile Software Engineering and Systems (MOBILESoft '24). Association for Computing Machinery, New York, NY, USA, 65–68. <https://doi.org/10.1145/3647632.3651389>
- [2] Mugdha Khedkar, Michael Schlichtig, and Eric Bodden. 2024. Advancing Android Privacy Assessments with Automation. In Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering Workshops (ASEW '24). Association for Computing Machinery, New York, NY, USA, 218–222. <https://doi.org/10.1145/3691621.3694953>
- [3] Mugdha Khedkar, Ambuj Kumar Mondal, and Eric Bodden. 2024. Do Android App Developers Accurately Report Collection of Privacy-Related Data? In Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering Workshops (ASEW '24). Association for Computing Machinery, New York, NY, USA, 176–186. <https://doi.org/10.1145/3691621.3694949>
- [4] Mugdha Khedkar, Michael Schlichtig, Nihad Atakishiyev et al. Assessor View: Introducing Tool Support for Android Privacy Assessments, 22 April 2025, PREPRINT (Version 1) available at Research Square <https://doi.org/10.21203/rs.3.rs-6323701/v1>

Backup Slides



Towards GDPR Compliance

```
1. ex:App dpv:Process ;  
2. dpv:hasPersonalData pd:Phone ;  
3. dpv:hasProcessing 1.dpv:Collect ;  
4. dpv:hasTechnicalMeasure  
   dpv:2.HashFunction .
```

- Phone number collected, and hashed
- Uses a technical measure before processing data
- Adheres to GDPR Article 25

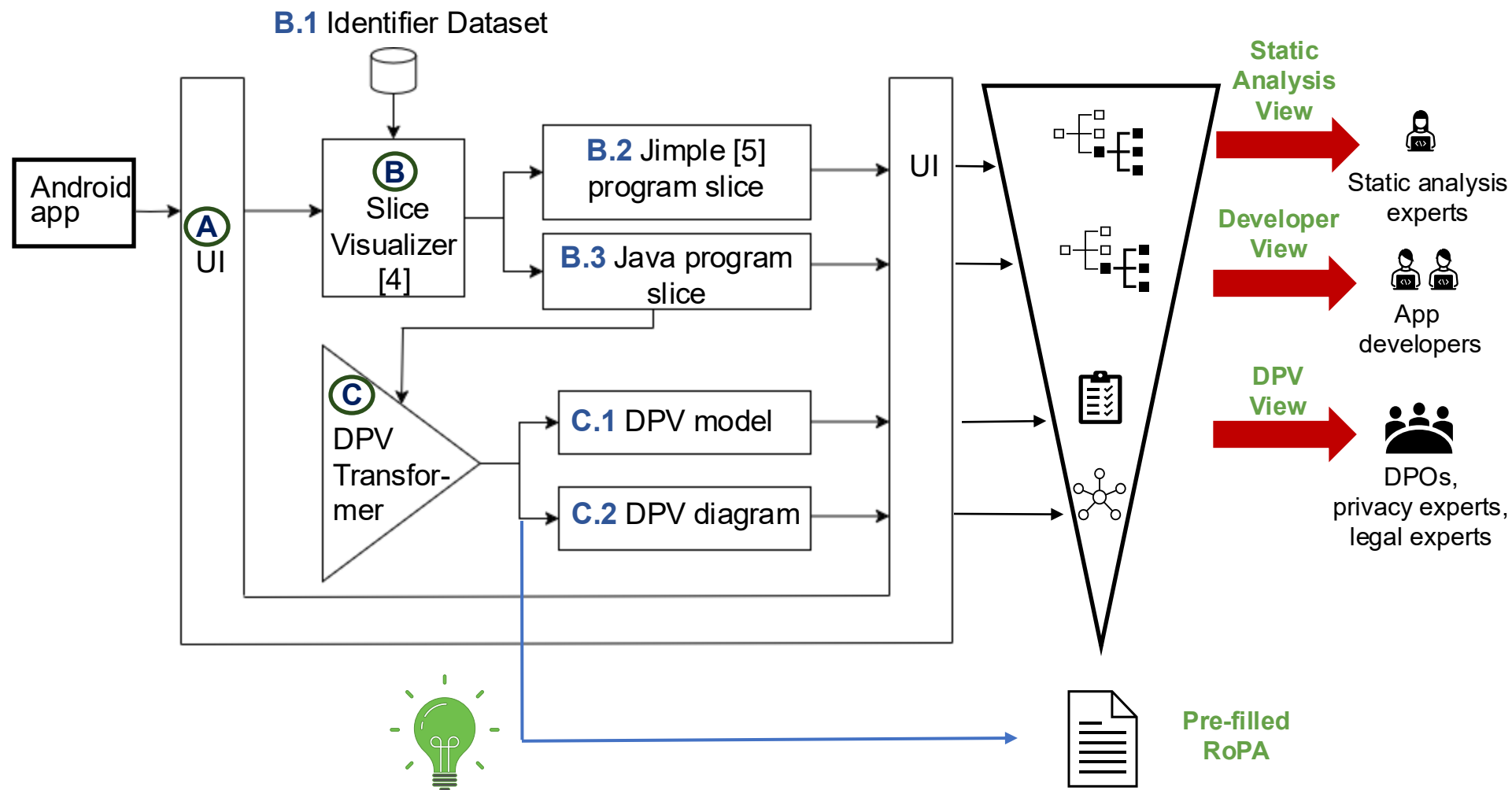


```
1. ex:App dpv:Process ;  
2. dpv:hasPersonalData pd:Email ;  
3. Dpv:hasDataSource dpv:ThirdParty ;  
4. dpv:hasProcessing 1.dpv:Collect,  
   2.dpv:Store ;
```

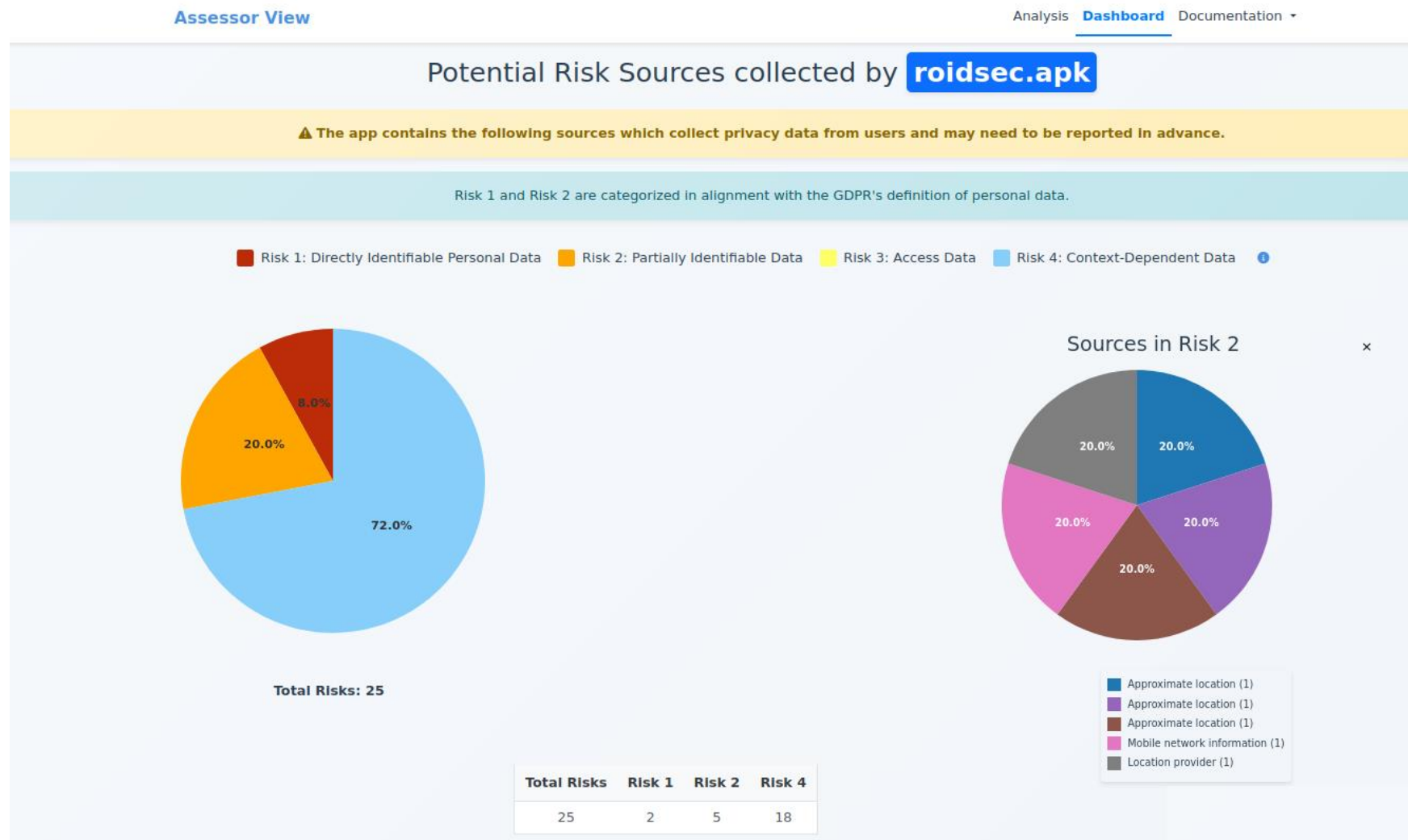
- Email address collected by Google Play Services (third party library) and written to Google storage
- No technical measure before processing data
- Violates GDPR Article 25
- Third party collection should adhere to GDPR Article 5



Assessor View



Assessor View Dashboard



Risk 1

Source ⓘ	Warning Scale ⓘ↕	Graph Views ⓘ	GDPR Warning ⓘ	Assessment Flag
Device ID	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼
Phone number	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼

Risk 2

Source ⓘ	Warning Scale ⓘ↕	Graph Views ⓘ	GDPR Warning ⓘ	Assessment Flag
Approximate location	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼
Approximate location	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼
Approximate location	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼

DPV View

DPV Model

1. **ap:** Droid **dpv:** *Process* ;
2. **dpv:hasPersonalData** *pd: Tracking, pd: Location, pd: GPSCoordinate*
3. **dpv: hasProcessing** 1. *dpv:Collect* ; 2. *dpv:Combine* ;

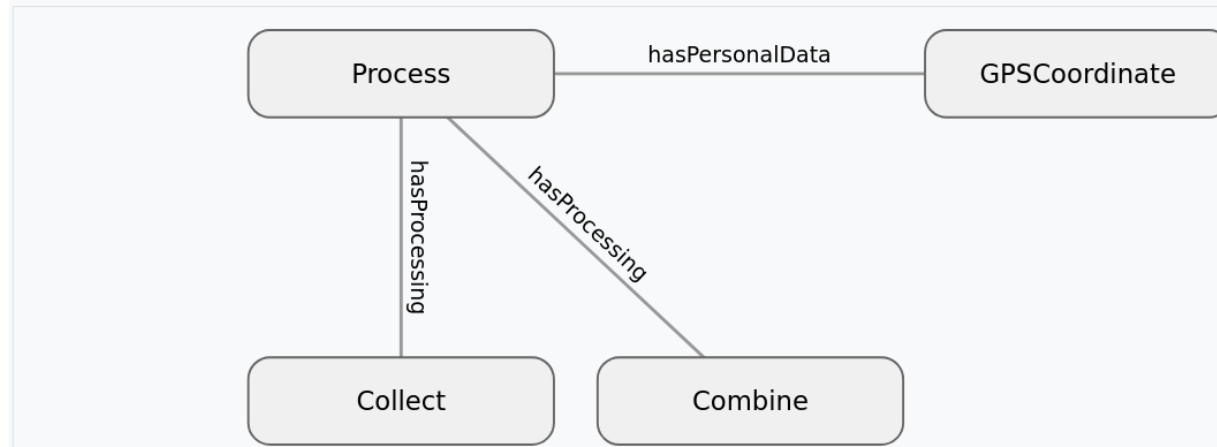
DPV Model - Explained

This section of the application processes personal data of type

G P S Coordinate .

It undergoes processing operations in the following order: **Collect** , **Combine** .

DPV Diagram



DPV Model

DPV Model - Explained

1. Data collection

⚠ This part of the app code is collecting data. Please ensure transparency by reporting this data collection through the privacy policy and Google Play Store's data safety section.

Legal Recommendation: Check reporting documents to decide adherence to GDPR Article 13.

Severity: Medium

[Read more on GDPR \(Article 13\)](#)

3. Processing of data in the absence of technical measures

⚠ This part of the app code is collecting and processing data, in the absence of technical measures (pseudonymization).

Legal Recommendation: Developers should be asked to clarify the legal basis and purpose for not applying pseudonymization. The absence of a valid legal justification for not implementing technical measures could constitute a violation of GDPR Articles 25 and 32.

✓ **Recommended technical measure:** encryption

✗ **Avoid technical measure:** scrambling

Severity: High

[Read more on GDPR \(Article 25\)](#)

Collect

Combine

RoPA

Editable fields for DPOs

ROPA Table

Personal Data	Process Activity	Description of Processing Activity	Thlrd Party Libraries	Purpose	GDPR Articles	Special Categories of Data?	DPO Remarks
Approximate location	Collect	To gather data from someone.	Not Found	Enter purpose for the processing activity here	§ 13 § 25	Is this a special category of Data?	Enter DPO remarks
	Combine	To join or merge data.	Not Found	Enter purpose for the processing activity here			
Phone number	Collect	To gather data from someone.	Not Found	Enter purpose for the processing activity here	§ 13 § 25	Is this a special category of Data?	Enter DPO remarks
	Copy	To produce an exact reproduction of the data.	Not Found	Enter purpose for the processing activity here			
	Combine	To join or merge data.	Not Found	Enter purpose for the processing activity here			

RoPA

Editable fields for DPOs

Progress bar

The screenshot displays the iapp RoPA tool interface. It features two main sections for data types, each with a progress bar on the right. The first section, 'Personal Data Type: Approximate location', has a progress bar at 50%. Below it, 'Processing Activities: Collect, Combine' is shown. Under this, there are two activities: 'Processing activity: Collect' (unchecked) and 'Processing activity: Combine' (checked). Each activity has fields for 'Description', 'Purpose', and 'Third-Party Libraries'. Arrows from the 'Editable fields for DPOs' label point to the 'Purpose' fields of both activities. The second section, 'Personal Data Type: Phone number', has a progress bar at 0% and a 'Processing Activities: Collect, Copy, Combine' section. At the bottom, there are fields for 'GDPR Articles', 'Special Category of Data', 'Risks Identified', and 'DPO Comment'.

▼ Personal Data Type: Approximate location

▼ Processing Activities: Collect, Combine

☐ Processing activity: Collect

Description: To gather data from someone.

Purpose:

Third-Party Libraries: Not Found

☒ Processing activity: Combine

Description: To join or merge data.

Purpose: Find exact location

Third-Party Libraries: Not Found

GDPR Articles: [Article 13](#), [Article 25](#)

Special Category of Data:

Risks Identified: Risk 2

DPO Comment:

▼ Personal Data Type: Phone number

► Processing Activities: Collect, Copy, Combine